

5CC515 – Networks and Security

Lecture 8: Standards and Attacks

Ethernet and Layer 2

- Ethernet was:
 - Developed in late 1970s at Xerox
 - Standardised in 1983 as IEEE 802.3
 - Early packet (frame) based network
- Speeds:
 - Originally 2.94 Mbps, then 10, 100, 1000 Mbps
 - Theoretically 97% efficient due to header overhead
- Please see https://en.wikipedia.org/wiki/Ethernet_frame section on Throughput, this is examinable

Address Resolution Protocol

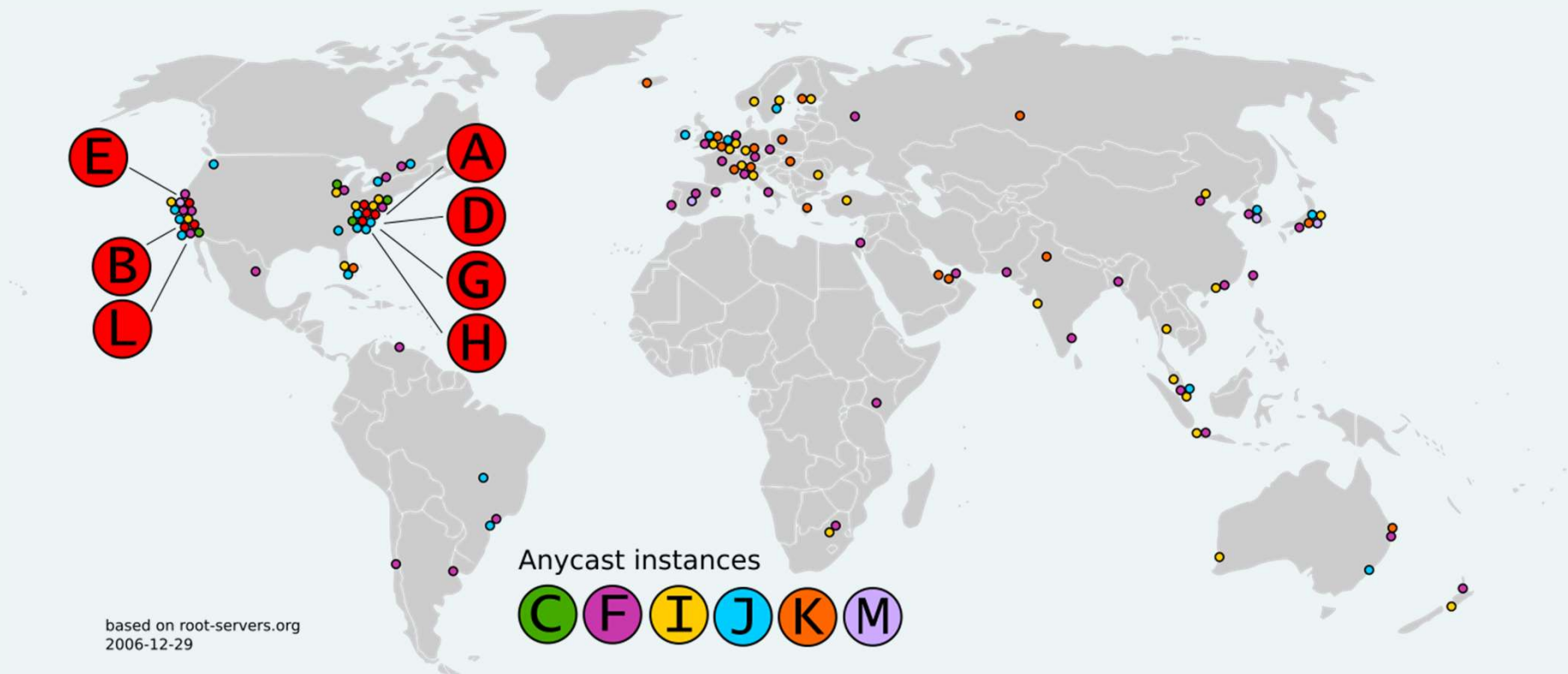
- RFC 826 (1983)
- In essence:
 - Attempt to lookup the MAC address of destination host
 - If found – awesome, forward the packet
 - Otherwise
 - Broadcast to all attached collision domains
 - Wait for a response
 - Add responses to our lookup table
- RFC and content at https://en.wikipedia.org/wiki/Address_Resolution_Protocol are examinable materials.

Attacking ARP

- ARP is a relatively simple protocol generally most vulnerable to spoofing/cache poisoning
- False ARP packets are sent by the attacker to link their MAC address to an IP address of a valid device on the network
- This enables:
 - Denial of service attacks – multiple nodes traffics directed at one node
 - Session hijacking – direct interception of unprotected data via stealing session ids
 - Man in the middle attacks – Allow the attacker to intercept the targets traffic by pretending to be both sides
 - Connection resetting

https://en.wikipedia.org/wiki/ARP_spoofing

DNS Root Servers



Distributed Hierarchical Database

- Why *distributed* DNS?
 - Structured subset of the database
 - Provides worldwide coverage
 - Content is replicated across multiple servers
- Benefits of *distribution*
 - Many points of failure
 - Traffic is localised
 - 'No' centralised database
 - Supports maintenance
- Why make it *hierarchical*?
 - Lexically based subset of the database
 - Resolution is bounded by hierarchy
 - Name servers can cache results efficiently
- Benefits of a *hierarchy*
 - Scales well
 - Smaller database at each name server
 - Entities are responsible for their own DNS entries

Iterative or Recursive?

- Iterative resolution
 - Scalable solution
 - Provides '*best effort*' match
 - Requires multiple lookups from the requesting DNS server
 - More complex to implement lookup process
- Recursive resolution
 - Places resource burden on contacted name server
 - Provides *exact match*
 - Requires single lookup from requesting DNS server
 - More complex to implement error checking and support
- Real world uses both
 - End hosts implement recursive solution – send request for an exact match
 - Local NS and DNS NS hierarchy implement iterative solution to place load on requesting nodes
 - Caches are optimal in both solutions

DNS Attacks

- There are many common attacks on the DNS system
 - Cache Poisoning
 - DNS Hijacking
 - Domain Hijacking / DNS Redirection
 - MITM Attacks
 - TCP SYN Flooding
 - UDP Flooding
 - Spoofed source address attacks
 - DNS Tunnelling
 - NXDomain attacks (non-existent domains)
 - Random Subdomain attacks (non-existent sub-domain)

<https://www.infoblox.com/sites/infobloxcom/files/resources/infoblox-whitepaper-top5-dns-security-attack-risks-how-to-avoid-them.pdf>

Authentication and Authorisation

- One of the most commonly used techniques on the Internet for authentication is a username and password
- What is a strong password?
 - aaaa
 - password
 - Password
 - Pa\$\$word
 - Pa\$\$word1
 - CorrectHorseBatteryStaple

Password Complexity

Entropy per symbol for different symbol sets						
Symbol set	Symbol count N	Entropy per symbol H	Length of Password (Chars)	Only Numbers	Mixed Lower and Upper case alphabets	Mixed numbers, Lower and Upper case alphabets
Arabic numerals (0–9) (e.g. PIN)	10	3.322 bits				
hexadecimal numerals (0–9, A–F) (e.g. WEP keys)	16	4.000 bits				
Case insensitive Latin alphabet (a–z or A–Z)	26	4.700 bits				
Case insensitive alphanumeric (a–z or A–Z, 0–9)	36	5.170 bits	3	Instantly	Instantly	Instantly
			4	Instantly	Instantly	Instantly
			5	Instantly	Instantly	3 secs
Case sensitive Latin alphabet (a–z, A–Z)	52	5.700 bits	6	Instantly	8 secs	3 mins
			7	Instantly	5 mins	3 hours
			8	Instantly	3 hours	10 days
Case sensitive alphanumeric (a–z, A–Z, 0–9)	62	5.954 bits	9	4 secs	4 days	153 days
			10	40 secs	169 days	1 year
All ASCII printable characters except space	94	6.555 bits	11	6 mins	16 years	106 years
			12	1 hour	600 years	6k years
All Latin-1 Supplement characters	94	6.555 bits	13	11 hours	21k years	108k years
			14	4 days	778k years	25m years
All ASCII printable characters	95	6.570 bits	15	46 days	28m years	1bn years
			16	1 year	1bn years	97bn years
All extended ASCII printable characters	218	7.768 bits	17	12 years	36bn years	6tn years
Binary (0–255 or 8 bits or 1 byte)	256	8.000 bits	18	126 years	1tn years	374tn years
Diceware word list	7776	12.925 bits per word				

Password Lengths

Desired password entropy H	Arabic numerals	Hexadecimal	Case insensitive		Case sensitive		All ASCII		All Extended ASCII	Diceware word list
			Latin alphabet	alpha-numeric	Latin alphabet	alpha-numeric	printable characters			
8 bits (1 byte)	3	2	2	2	2	2	2	2	1 word	
32 bits (4 bytes)	10	8	7	7	6	6	5	5	3 words	
40 bits (5 bytes)	13	10	9	8	8	7	7	6	4 words	
64 bits (8 bytes)	20	16	14	13	12	11	10	9	5 words	
80 bits (10 bytes)	25	20	18	16	15	14	13	11	7 words	
96 bits (12 bytes)	29	24	21	19	17	17	15	13	8 words	
128 bits (16 bytes)	39	32	28	25	23	22	20	17	10 words	
160 bits (20 bytes)	49	40	35	31	29	27	25	21	13 words	
192 bits (24 bytes)	58	48	41	38	34	33	30	25	15 words	
224 bits (28 bytes)	68	56	48	44	40	38	35	29	18 words	
256 bits (32 bytes)	78	64	55	50	45	43	39	33	20 words	

What do people actually use

Rank	2011 ^[6]	2012 ^[7]	2013 ^[8]	2014 ^[9]	2015 ^[10]	2016 ^[5]	2017 ^[11]	2018 ^[12]	2019 ^[13]
1	password	password	123456	123456	123456	123456	123456	123456	123456
2	123456	123456	password	password	password	password	password	password	123456789
3	12345678	12345678	12345678	12345	12345678	12345	12345678	123456789	qwerty
4	qwerty	abc123	qwerty	12345678	qwerty	12345678	qwerty	12345678	password
5	abc123	qwerty	abc123	qwerty	12345	football	12345	12345	1234567
6	monkey	monkey	123456789	123456789	123456789	qwerty	123456789	111111	12345678
7	1234567	letmein	111111	1234	football	1234567890	letmein	1234567	12345
8	letmein	dragon	1234567	baseball	1234	1234567	1234567	sunshine	iloveyou
9	trustno1	111111	iloveyou	dragon	1234567	princess	football	qwerty	111111
10	dragon	baseball	adobe123 ^[a]	football	baseball	1234	iloveyou	iloveyou	123123
11	baseball	iloveyou	123123	1234567	welcome	login	admin	princess	abc123
12	111111	trustno1	admin	monkey	1234567890	welcome	welcome	admin	qwerty123
13	iloveyou	1234567	1234567890	letmein	abc123	solo	monkey	welcome	1q2w3e4r
14	master	sunshine	letmein	abc123	111111	abc123	login	666666	admin
15	sunshine	master	photoshop ^[a]	111111	1qaz2wsx	admin	abc123	abc123	qwertyuiop
16	ashley	123123	1234	mustang	dragon	121212	starwars	football	654321
17	bailey	welcome	monkey	access	master	flower	123123	123123	555555
18	passw0rd	shadow	shadow	shadow	monkey	passw0rd	dragon	monkey	lovely
19	shadow	ashley	sunshine	master	letmein	dragon	passw0rd	654321	7777777
20	123123	football	12345	michael	login	sunshine	master	!@#%\$^&*	welcome

Password Attacks

- We can attack passwords in many ways:
 - Brute force attacks - unrealistic
 - Dictionary attacks – common words, only if unsalted
 - Database compromise (finding the hashes)
 - Rainbow tables (list of hash:word)
 - Key logging

https://en.wikipedia.org/wiki/Rainbow_table

Security Standards



What you can do to combat cyber attacks

Reducing The Impact
Most cyber attacks are composed of four stages: **Survey, Delivery, Breach and Affect**. The following **security controls**, applied at each stage of an attack, can reduce your organisation's exposure to a successful cyber attack.

Survey

User Education
Train all users to consider what they include in publicly available documents and web content. Users should also be aware of the risks from discussing work-related topics on social media, and the potential of being targeted by phishing attacks.

Who might be attacking you?
Cyber Criminals interested in making money through fraud or from the sale of valuable information.
Industrial competitors and foreign intelligence services interested in gaining an economic advantage for their companies or countries.
Hackers who find interfering with computer systems an enjoyable challenge.
Hacktivists who wish to attack companies for political or ideological motives.
Employees, or those who have legitimate access, either by accidental or deliberate misuse.

Delivery

Network Perimeter Defences
Can block insecure or unnecessary services, or only allow permitted websites to be accessed.

Malware Protection
Can block malicious emails and prevent malware being downloaded from websites.

Password Policy
Can prevent users from selecting easily guessed passwords and locks accounts after a low number of failed attempts.

Secure Configuration
Restrict system functionality to the minimum needed for business operation, systematically apply to every device that is used to conduct business.

Breach

Patch Management
Apply patches at the earliest possibility to limit exposure to known software vulnerabilities.

Monitoring
Monitor and analyse all network activity to identify any malicious or unusual activity.

Malware Protection
Malware protection within the internet gateway can detect malicious code in an important item.

Secure Configuration
Remove unnecessary software and default user accounts. Ensure default passwords are changed, and that automatic features that could activate malware are turned off.

User Access
Well maintained user access controls can restrict the applications, privileges and data that users can access.

User Training
User training is extremely valuable in reducing the likelihood of successful social engineering attacks.

Device Controls
Devices within the internal gateway should be used to prevent unauthorised access to critical services or inherently insecure services that may still be required internally.

Affect

Controls For The Affect Stage
Once an attacker has achieved full access, it's much harder to detect their actions and eradicate their presence. This is where a more in-depth, holistic approach to cyber security can help. **10 Steps To Cyber Security** outlines many of the features of a complete cyber risk management regime.

£600K-£1.15m
Average cost of security breach

81% of large companies reporting breach

For more information go to www.ncsc.gov.uk @ncsc



10 Steps to Cyber Security

Defining and communicating your Board's Information Risk Regime is central to your organisation's overall cyber security strategy. The National Cyber Security Centre recommends you review this regime – together with the nine associated security areas described below, in order to protect your business against the majority of cyber attacks.

Network Security

Protect your networks from attack. Define the network perimeter, filter out unauthorised access and malicious content. Monitor and test security controls.

User education and awareness

Produce user security policies covering acceptable and secure use of your systems. Include in staff training. Maintain awareness of cyber risks.

Malware prevention

Produce relevant policies and establish anti-malware defences across your organisation.

Removable media controls

Produce a policy to control all access to removable media. Limit media types and use. Scan all media for malware before importing onto the corporate system.

Secure configuration

Apply security patches and ensure the secure configuration of all systems is maintained. Create a system inventory and define a baseline build for all devices.

Managing user privileges

Establish effective management processes and limit the number of privileged accounts. Limit user privileges and monitor user activity. Control access to activity and audit logs.

Incident management

Establish an incident response and disaster recovery capability. Test your incident management plans. Provide specialist training. Report criminal incidents to law enforcement.

Monitoring

Establish a monitoring strategy and produce supporting policies. Continuously monitor all systems and networks. Analyse logs for unusual activity that could indicate an attack.

Home and mobile working

Develop a mobile working policy and train staff to adhere to it. Apply the secure baseline and build to all devices. Protect data both in transit and at rest.

Set up your Risk Management Regime
Assess the risks to your organisation's information and systems with the same vigour you would for legal, regulatory, financial or operational risks. To achieve this, embed a Risk Management Regime across your organisation, supported by the Board and senior managers.

Make cyber risk a priority for your Board

Produce supporting risk management policies

Determine your risk appetite

For more information go to www.ncsc.gov.uk @ncsc

Security Standards

- In 2018 the UK Government put forward the [minimum cyber security standard](#)

Identify

1. Departments shall put in place appropriate cyber security governance processes.
2. Departments shall identify and catalogue sensitive information they hold.
3. Departments shall identify and catalogue the key operational services they provide.
4. The need for users to access sensitive information or key operational services shall be understood and continually managed.

Protect

5. Access to sensitive information and key operational services shall only be provided to identified, authenticated and authorised users of systems.
6. Systems which handle sensitive information or key operational services shall be protected from exploitation of known vulnerabilities.
7. Highly privileged accounts shall not be vulnerable to common cyber-attacks.

Detect

8. Departments shall take steps to detect common cyber-attacks.

Respond

9. Departments shall have a defined, planned and tested response to cyber security incidents that impact sensitive information or key operational services.

Recover

10. Departments shall have well defined and tested processes in place to ensure the continuity of key operational services in the event of failure or compromise.

ISO 27001

- [ISO 27001](https://www.iso.org/standard/54539.html) is an international standard that defines what is effectively a checklist for an information security management system
- It doesn't specify a set of rules a company must apply but a set of things that they should consider and have addressed
- Its broken down into 12 sections – you can read about it in plain English here: <https://www.praxiom.com/iso-27001.htm>
 1. Risk assessment
 2. Security policy
 3. Organization of information security
 4. Asset management
 5. Human resources security
 6. Physical and environmental security
 7. Communications and operations management
 8. Access control
 9. Information systems acquisition, development and maintenance
 10. Information security incident management
 11. Business continuity management
 12. Compliance

ISO 22301 and ISO

- [ISO 22301](#) covers the business continuity model – basically what happens when you have a disruptive incident
- <https://www.praxiom.com/iso-22301.htm> – describes this in plain English
- [ISO 27032](#) covers the information technology security techniques for cyber security

Cyber Assessment Framework

- <https://www.ncsc.gov.uk/collection/caf/cyber-assessment-framework>
 - <https://www.ncsc.gov.uk/collection/caf/caf-principles-and-guidance>
 - **Objective A: Managing security risk**
 - Appropriate organisational structures, policies, and processes are in place to understand, assess and systematically manage security risks to the network and information systems supporting essential functions.
 - A.1 Governance
 - A.2 Risk management
 - A.3 Asset management
 - A.4 Supply chain
 - **Objective B: Protecting against cyber attack**
 - Proportionate security measures are in place to protect the network and information systems supporting essential functions from cyber attack.
 - B.1 Service protection policies and processes
 - B.2 Identity and access control
 - B.3 Data security
-

Cont.

- B.4 System security
- B.5 Resilient networks and systems
- B.6 Staff awareness and training
- **Objective C: Detecting cyber security events**
 - Capabilities exist to ensure security defences remain effective and to detect cyber security events affecting, or with the potential to affect, essential functions.
 - C.1 Security monitoring
 - C.2 Proactive security event discovery
- **Objective D : Minimising the impact of cyber security incidents**
 - Capabilities exist to minimise the adverse impact of a cyber security incident on the operation of essential functions, including the restoration of those functions where necessary.
 - D.1 Response and recovery planning
 - D.2 Lessons learned

CAF – What does it require

B1.b Policy and Process Implementation

You have successfully implemented your security policies and processes and can demonstrate the security benefits achieved.

Not achieved	Partially achieved	Achieved
At least one of the following statements is true	All of the following statements are true	All the following statements are true
Policies and processes are ignored or only partially followed.	Most of your policies and processes are followed and their application is monitored.	All your policies and processes are followed, their correct application and security effectiveness is evaluated.
The reliance on your policies and processes is not well understood.	Your policies and processes are integrated with other organisational policies and processes, including HR assessments of individuals' trustworthiness.	Your policies and processes are integrated with other organisational policies and processes, including HR assessments of individuals' trustworthiness.
Staff are unaware of their responsibilities under your policies and processes.	All staff are aware of their responsibilities under your policies and processes.	Your policies and processes are effectively and appropriately communicated across all levels of the organisation resulting in good staff awareness of their responsibilities.
You do not attempt to detect breaches of policies and processes.	All breaches of policies and processes with the potential to adversely impact the essential function are fully investigated. Other breaches are tracked, assessed for trends and action is taken to understand and address.	Appropriate action is taken to address all breaches of policies and processes with potential to adversely impact the essential function including aggregated breaches.
Policies and processes lack integration with other organisational policies and processes.		
Your policies and processes are not well communicated across your organisation.		

What does this mean

- Cyber security is hard
 - Cyber security is hard to define
 - Cyber security is hard to set standards for
 - Cyber security is hard because it's a moving standard
-
- Cyber security is about putting processes in place to manage risk not to negate it
 - Cyber security is about planning, education, prevention, and management

THANK YOU